

From Customer Voice to Delivery Execution

FINEXA · MERCHANT EXPERIENCE PRODUCT GROUP · PAYMENTS PILOT

12-Week Hybrid Agentic System Pilot

Risk Mitigation Analysis



Prepared by
Margarita Sergeeva
AI Project Management | THRIVE & Kiron Education
margaret.sergeeva@gmail.com
www.linkedin.com/in/margaritasergeeva/

August 2026

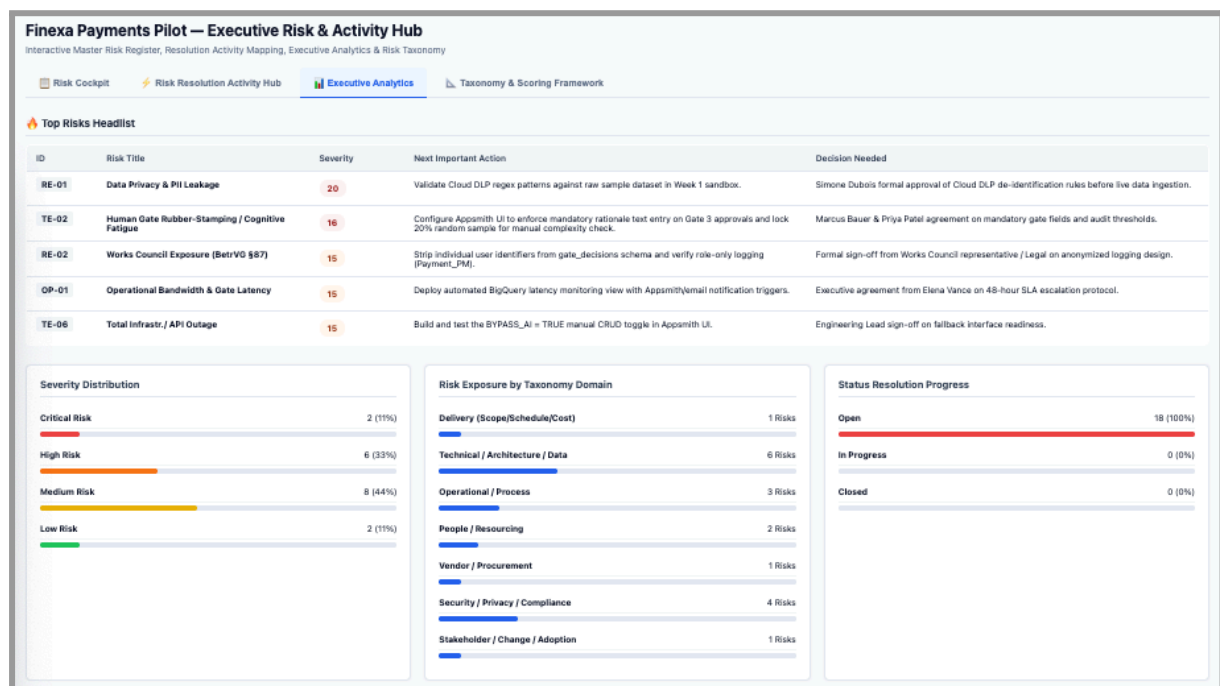
From Customer Voice to Delivery Execution

FINEXA · MERCHANT EXPERIENCE PRODUCT GROUP · PAYMENTS PILOT · RISK MITIGATION ANALYSIS

1. Executive Summary

To ensure an easy overview of the Project's risks and required actions and decisions we have published the entire Project risk register into a live, interactive **Risk Management Hub**.

Picture 1: Finexa Executive Risk Hub, Taxonomy & Scoring Framework. Click on the diagram to get more information.



Risks Requiring Decisions Now

- **GDPR Right-to-Erasure Policy:** Formal executive decision on whether a right-to-erasure request triggers a soft erasure (anonymizing derived insights) or a hard cascade wipe (purging historical scores and ticket lineage)
- **Works Council (BetrVG §87) Sign-Off:** Explicit agreement on reviewer anonymity protocols (logging functional roles like Payment_PM rather than employee IDs) before live execution (Pilot Project Brief, p. 11).
- **Legitimate Interest & merchant_id Classification:** Formal LIA sign-off and approval of the entity-type classification rule (sole proprietor vs. corporate) governing merchant_id and feedback-ingestion processing.

Top 5 Risks

1. **RE-01 (Severity 20):** Incomplete Cloud DLP redaction leaks merchant PII or financial data into LLM prompts, leading to regulatory sanctions under GDPR and immediate pilot blockage by Risk & Compliance.
2. **TE-02 / OP-05 (Severity 16):** Reviewer cognitive fatigue causes human gatekeepers to blindly rubber-stamp AI drafts, leading to low-quality/hallucinated user stories entering the engineering backlog.
3. **RE-02 (Severity 15):** Logged review actions enable indirect performance tracking of PMs, leading to Works Council (BetrVG §87) intervention and project suspension.
4. **OP-01 (Severity 15):** Daily PM operational duties delay human gate approvals beyond 48 hours, leading to workflow bottlenecks and schedule slippage across the 12-week pilot runway.
5. **TE-06 (Severity 15):** Upstream LLM provider outages or API downtime halt the Appsmith UI, leading to total operational paralysis of the discovery pipeline.

Key Assumptions Affecting Risk Posture

- **Merchant Account Tier availability:** merchant_account_tier exists as a queryable field in Finexa merchant databases.
- **Merchant ID classification and Legitimate Interest basis are pending Simone Dubois/Legal sign-off.**
- **Core reviewers (Marcus Bauer, Priya Patel) have dedicated bandwidth (~15–30 min daily) throughout all 12 weeks.**
- **BigQuery and Jira service accounts, including REST API ticket creation, can be safely integrated with credential isolation.**

Biggest Exposure Themes

- **Compliance & Data Privacy:** Exposure around GDPR data handling, EU AI Act categorization, and Works Council employee monitoring constraints (BetrVG §87)
- **Human Gate Operations & Adoption:** Dependencies on Marcus Bauer and Priya Patel maintaining consistent review bandwidth without succumbing to rubber-stamping or bypassing Appsmith for spreadsheets (CS, p. 6–7).
- **Engineering Backlog Quality:** Operational friction caused if unverified, poorly structured, or hallucinated requirements bypass Gate 3 and reach engineering sprints.
- **System Integration & Failure Recovery:** Potential failure points across BigQuery schema changes, Jira API wrapper timeouts or prompt injection attacks.

2. Top Risks Heatlist

ID	Risk Title	Severity	Next Important Action	Decision Needed
RE-01	Data Privacy & PII Leakage	20	Validate Cloud DLP regex patterns against raw sample dataset in Week 1 sandbox	Simone Dubois formal approval of Cloud DLP de-identification rules before live data ingestion
TE-02	Human Gate Rubber-Stamping / Cognitive Fatigue	16	Configure Appsmith UI to enforce mandatory rationale text entry on Gate 3 approvals and lock 20% random sample for manual complexity check	Marcus Bauer & Priya Patel agreement on mandatory gate fields and audit thresholds
RE-02	Works Council Exposure (BetrVG §87)	15	Strip individual user identifiers from gate_decisions schema and verify role-only logging (Payment_PM)	Formal sign-off from Works Council representative / Legal on anonymized logging design
OP-01	Operational Bandwidth & Gate Latency	15	Deploy automated BigQuery latency monitoring view with Appsmith/email notification triggers	Executive agreement from Elena Vance on 48-hour SLA escalation protocol
TE-06	Total Infrastr./ API Outage	15	Build and test the BYPASS_AI = TRUE manual CRUD toggle in Appsmith UI	Engineering Lead sign-off on fallback interface readiness

3. Executive Decision Requests

Decision Needed	Decision Owner	Target	Impact if Delayed
Approval of Cloud DLP de-identification rules & merchant_id handling	Simone Dubois (Risk & Compliance)	Week 1	Live data ingestion cannot begin; pilot halted.

Decision Needed	Decision Owner	Target	Impact if Delayed
Adoption of Soft Erasure Policy for GDPR right-to-erasure requests	Simone Dubois / Legal	Week 2	Risks data loss or non-compliance during pilot execution.
Sign-off on Works Council anonymity framework (role vs user_id)	Simone Dubois / HR / Works Council	Week 2	Risk of labor union objection and system shutdown.
Executive mandate for 48-hour gate latency SLA and escalation protocol	Elena Vance (Head of Product)	Week 2	Unresolved review bottlenecks cause pilot schedule overrun.

4. Risk Response Plan

Next 10 Actions in the Next 2 Weeks

Action / Task	Description	Owner	Mitigated Risk
Execute Cloud DLP Validation Test	Run DLP scrubbing on 25 sample interview transcripts to verify 0% PII leak rate.	Simone Dubois	RE-01
Configure Role-Only Logging Schema	Update gate_decisions BigQuery table DDL to log functional role metadata only.	External Consultant	RE-02
Establish Baseline Metric Capture	Finalize pure manual baseline timing benchmarks in BigQuery	External Consultant	OP-04
Provision Appsmith Access & Roles	Grant Appsmith UI access and permission roles to Marcus Bauer and Priya Patel.	Priya Patel	OP-02 & OP-01
Configure Latency Alert Telemetry	Build automated query alerting Elena Vance if avg_gate_latency_hours > 48.	External Consultant	OP-01

Action / Task	Description	Owner	Mitigated Risk
Implement Deterministic Priority Formula View	Deploy opportunity_priority_metrics SQL view with weighted formula.	External Consultant	TE-01
Build Jira Wrapper Two-Phase Commit	Code PENDING_SYNC status step in Jira dispatch wrapper.	Priya Patel	TE-07
Establish Read-Only MCP Connection	Configure /ask_data Model Context Protocol agent with read-only IAM rights.	Priya Patel	TE-08
Set Up Gate 3 Forced Sample Check	Code Appsmith logic locking every 5th draft for manual complexity entry.	External Consultant	TE-02
Publish Command Execution SOP	Deliver standard operating guidelines for /process-feedback and /draft-user-story.	Marcus Bauer	TE-03
Confirm legal_entity_type classification rule	Verify legal_entity_type exists on merchant KYC records; define sole-proprietor vs. corporate classification rule for merchant_id.	Simone Dubois	RE-01 / RE-02

5. Dependencies & Single Points of Failure (SPOF)

SPOF	Why It Matters	Risk(s)	Owner	Mitigation
Google Cloud DLP Engine	Essential edge control preventing raw PII from reaching third-party LLM APIs (Pilot Brief, p. 5).	RE-01	Simone Dubois	Implement strict pre-ingestion validation checks and automated regex tests.
BigQuery Central Staging Repository	Serves as the Single Source of Truth (SSOT) for feedback, vector embeddings, and gate decisions (Pilot Brief, p. 5).	TE-06, TE-10	Priya Patel	Enforce schema abstraction views and automated daily BigQuery backups.

SPOF	Why It Matters	Risk(s)	Owner	Mitigation
Jira Dispatch Wrapper Script	Sole component holding Jira API credentials; bridges BigQuery to engineering backlog (Pilot Brief, p. 5).	TE-06, TE-07	Priya Patel	Two-Phase Commit architecture (PENDING_SYNC) and isolated service account key management.
Marcus Bauer (Senior PM Bandwidth)	Primary human gatekeeper for Gates 1 and 2 in the Payments domain (CS, p. 6).	OP-01, OP-02	Elena Vance	Appsmith UI workflow compression (88% time savings) and backup reviewer designation.

6. Compliance and Privacy Risk Notes

Applicable Policies & Regulations

- **GDPR (EU General Data Protection Regulation):** Applies to merchant feedback handling, data residency (EU-only), and right-to-erasure enforcement (Pilot Brief, p. 11).
- **EU AI Act:** Classified as an internal administrative/drafting tool (low risk), falling outside high-risk regulatory constraints as it makes no autonomous binding decisions (Pilot Brief, p. 11).
- **German Works Constitution Act (BetrVG §87):** Regulates employee monitoring and co-determination rights regarding performance logging (Pilot Brief, p. 11).

Project-Specific Compliance Risk Statements

- **RE-01 (PII Ingestion):** If unstructured customer transcripts contain unscrubbed payment card numbers or personal emails, then passing them to the LLM core violates GDPR data protection mandates, leading to regulatory fines and project shutdown.
- **RE-02 (Employee Monitoring):** If gate_decisions tables log individual PM timestamps and review speeds, then the system constitutes performance monitoring under BetrVG §87, leading to Works Council injunctions.

Open Compliance Questions

- Does the formal right-to-erasure policy permit Soft Erasure (anonymizing derived insights) without requiring cascading deletion across historical Jira tickets?
- Is merchant_id explicitly re-confirmed as non-personal corporate data by Legal when company names are retained for tier resolution at Gate 1?

7. Conflicts & Resolutions

Conflict Discovered	Originating Sources	Impact on Risk Posture	Owner	Proposed Resolution
Speed vs. Governance Checkpoints	Elena Vance demands fast turnaround (CS, p. 5); Priya Patel demands strict, non-negotiable review checkpoints (CS, p. 6).	Friction over review speed; potential for gate bypass or bottlenecking.	Elena Vance	Maintain strict Gate 1–3 checkpoints, but optimize UI layout to compress review time to < 4 minutes/item.
Prioritization Automation vs. Bias Concerns	Executive vision promotes automated priority scoring (CS, p. 2); Liam O'Connor fears operational escalations will be buried (CS, p. 7).	Stakeholder resistance and lack of trust in roadmap outputs.	Elena Vance / Marcus Bauer	Use deterministic formula where operational risk carries explicit tunable weight, combined with automated regression_flag override.
Erasure Scope (Hard Cascade vs. Soft Anonymization)	Compliance notes flag unresolved choice between deleting raw files vs. cascade deleting derived rows (Pilot Brief, p. 11).	Data loss vs. compliance	Simone Dubois	Adopt Soft Erasure Policy: purge direct identifiers while preserving anonymized derived insights for backlog integrity.

8. Open Questions

Resourcing & Ownership: Who acts as the official backup gate reviewer when Marcus Bauer or Priya Patel are on leave?

Vendors / Procurement: What are the rate limits and SLA guarantees on Finexa's current AI platform tenant?

Technical & Data Constraints: Are raw interview audio files being transcribed prior to ingestion, or is transcription within pilot scope?

Compliance & Security: Has a formal DPIA exemption letter been signed off?

Stakeholder Alignment & Adoption: What specific target score on the end-of-pilot stakeholder survey defines "stronger stakeholder confidence"?